MODULE 11

Social Engineering Crimes and Attacks

Certified Cyber Criminologist - Police / LEA Training

Samir Raja (CYBER07) | Cyber Crime Investigator & Offensive Security Researcher

What You Will Learn

Behind every cyber fraud there is human trickery. This module teaches you to **read the criminal's marks**.

- **What social engineering is** - hacking the human, not the computer
- **Vishing, smishing, pretexting, baiting** - the four weapons, with real patterns
- **Target profiling** - where criminals get your name before they call
- **Dissecting phishing links and emails** - header, SPF/DKIM/DMARC, URL forensics
- **Gang SOP** - how script patterns link cases to one gang
- **Evidence handling** - preserving emails, chats and QR codes for court

What Is Social Engineering, Really?

When the criminal cannot break the computer's password, he targets **the person who operates the computer**.

- Social engineering = **fooling a person** to get work done by them - the human is the vulnerability
- No malware needed: one phone call and one OTP can empty an account in seconds
- Your job is not to think like the criminal - it is to **read the criminal's marks** in every case

The Three Emotions Criminals Exploit



- **Fear** - arrest threats freeze thinking; the victim obeys without verifying
- **Greed** - fake prizes make the victim ignore every warning sign
- **Hurry** - deadlines kill verification; 'act now' means 'don't think'

Four Forms You Must Recognise

Same trick, four channels. Learn the names - victims describe them, you must **classify** them:

- **Vishing** (voice + phishing) - fraud over phone calls; fake bank officers, fake police
- **Smishing** (SMS + phishing) - fraud through SMS/WhatsApp; fake links, fake offers
- **Pretexting** - a false story to win trust; 'I am from customer care, your KYC expired'
- **Baiting** - luring with free gifts, lucky draws, job offers to harvest your data

Vishing Deep Dive: The Phone Call

Vishing is India's most reported fraud pattern. The caller follows a **script** - and scripts leave patterns:

- **Authority claim:** 'bank head office, Mumbai' or 'RBI rules' - borrowed uniforms of trust
- **Prior knowledge:** knows your name, your city - this is profiling, not magic
- **The ask:** OTP on the phone, or a screen-sharing app, or a QR scan - a real bank never asks
- **The block:** 'do not call back' - isolation keeps the victim from verifying

Anatomy of a Vishing Call



- Every vishing call has the same skeleton - learn it once, recognise it forever
- Background call-centre noise = the gang's office; note it in the victim's statement
- The transcript is evidence: get the victim to narrate **word by word**

Score the Call: Red-Flag Checklist



- **3-4 flags:** high fraud probability - cut the call, report on 1930
- **5-6 flags:** confirmed pattern - stop any in-progress payment immediately

Target Profiling: They Knew Your Name

Criminals do not call at random. When a victim says 'they knew everything about me', it means **profiling happened first**:

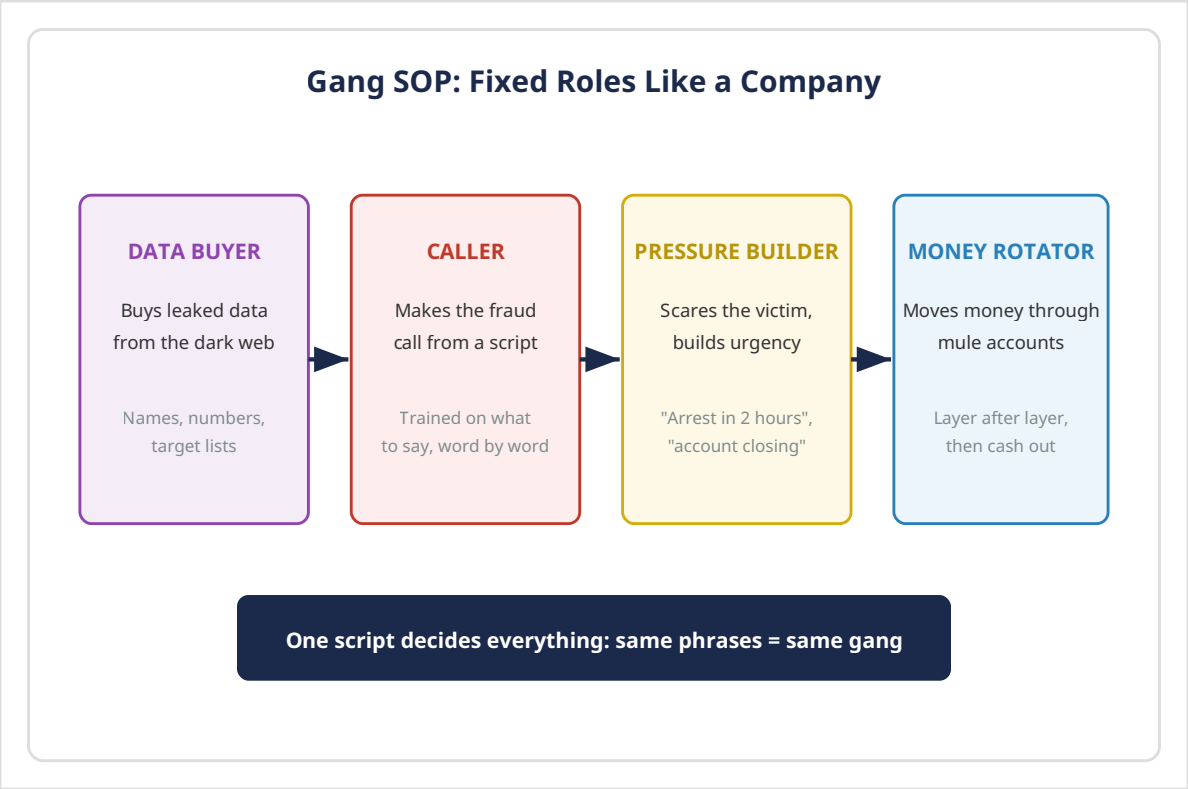
- **Data leaks:** breached company databases - name, number, email sold on the dark web
- **Social media:** victims post their own lives - workplace, kids' names, travel plans
- **Fake surveys and apps:** 'free recharge' forms harvest name, number, age, bank details

Finding the Leak: Your Investigation Question

One question must appear in every social-engineering case file: **where did the victim's data leak from?**

- Ask the victim: which surveys filled, which apps installed, which sites registered on recently
- Match the leaked fields against known breach databases - same fields, same breach
- The leak source is a **lead to the gang's data supplier** - follow it

Gang SOP: A Company of Criminals



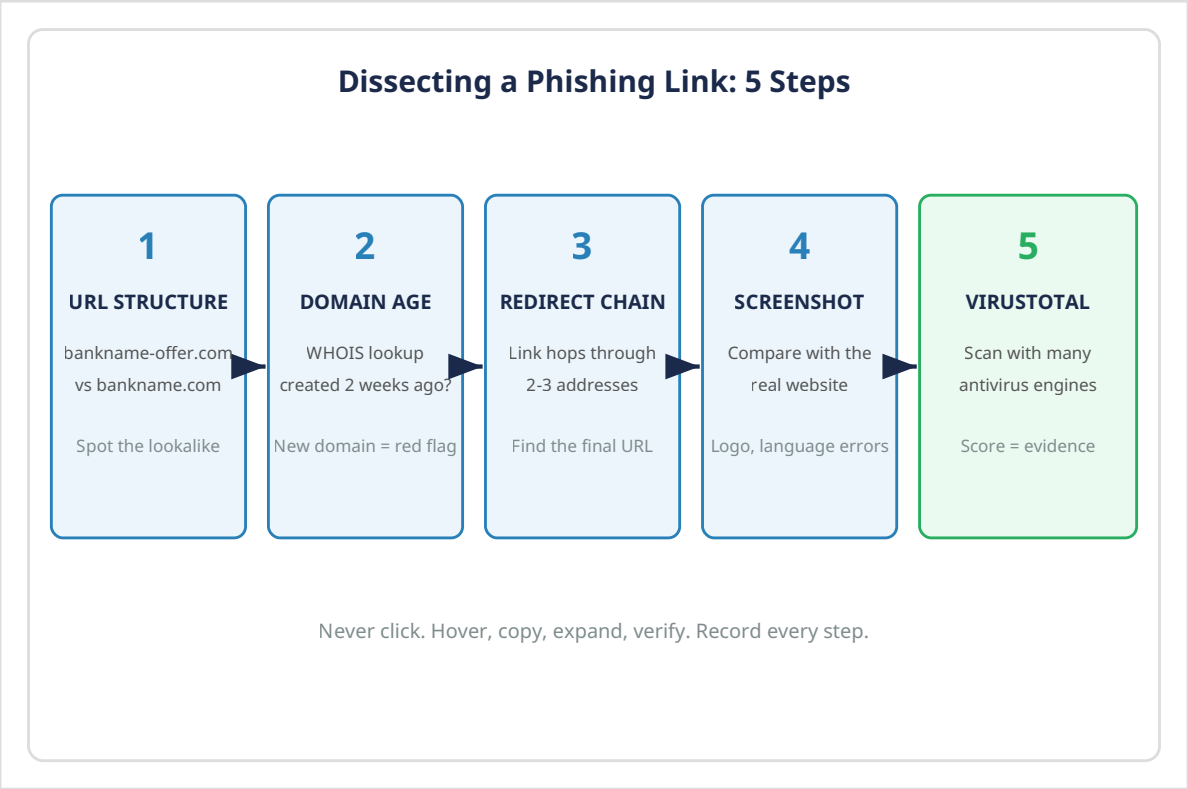
- New recruits are **trained** on scripts - what to say, how to handle panic, when to cut the call
- Everyone has a fixed role; nobody improvises - that rigidity is your advantage

Same Script = Same Gang

The SOP is the investigator's gift. Once you learn one gang's method, **you can recognise it in the next case**:

- Identical scare phrases in two cases ('arrest in two hours') point to one gang
- Same money-rotation pattern (same mule chain shape) confirms the link
- Build a **script library** at your unit: phrases, tactics, rotation patterns, per case

Dissecting a Phishing Link: 5 Steps



- Defensive and fully legal: you examine, you never build
- Record every step with date-time - the dissection report is court evidence

Two URL Tricks That Fool Eyes

Criminals hide the real address. Two tricks do most of the work - **learn to defeat both**:

- **URL shorteners** (bit.ly, tinyurl): expand first with a URL-expander tool, never open directly
- **Homograph trick:** letters that look identical but are different characters - copy the domain into a tool, do not trust your eyes
- Rule: hover to preview, copy to Notepad, expand, then verify - **never click first**

Email Attacks: Start with the Header

The inbox is the criminals' favourite weapon. Your examination starts where the victim cannot see - **the header**:

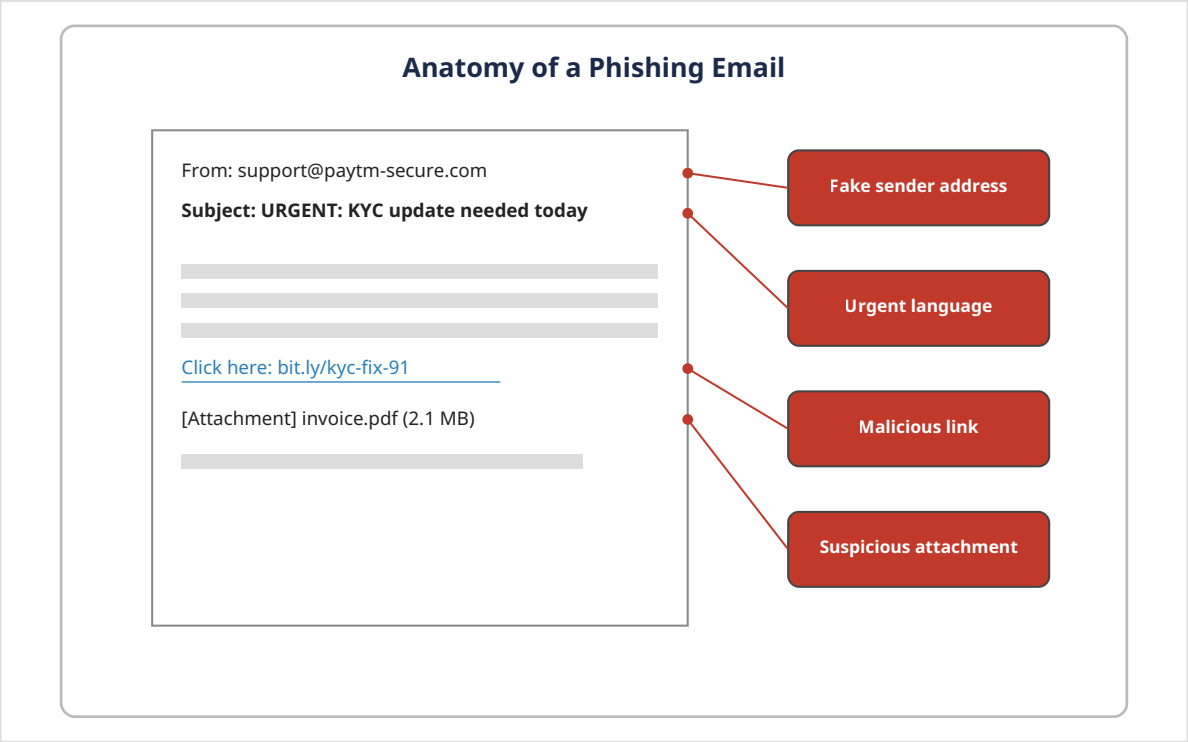
- The header shows the **real sending server** and the route - read Received lines bottom to top
- Display name 'HDFC Bank' but real address alert@hdfc-bank-alerts.xyz = first red flag
- Check **Reply-To**: replies may go to the criminal even when From looks real

SPF, DKIM, DMARC: The Three Gatekeepers

Three technical checks in the header prove whether an email is **genuinely from who it claims**:

- **SPF** - is the sending server allowed to send mail for this domain?
- **DKIM** - digital signature: was the mail altered on the way?
- **DMARC** - what to do when SPF/DKIM fail. **Fail on any = fake email**, firmly

Anatomy of a Phishing Email



- Ten evidence points in one email: subject, From vs Reply-To, server, SPF/DKIM/DMARC, link text vs real URL
- Attachments: **invoice.pdf.exe** - double extension means danger, always
- Save the original .eml file untouched - it is the evidence

BEC: Fraud in the Boss's Name

Business Email Compromise: the criminal **becomes the CFO** and orders an urgent transfer:

- Email to accounts staff: 'transfer immediately, confidential' - pressure kills verification
- Indian companies have lost **crores** to single BEC emails
- Defence you teach companies: **verify payment orders by phone** on a known number, always

Fake Surveys and Ad Fraud

'Two-minute survey, win Rs 500' - the gift never comes; **your data is the product**:

- Bogus surveys harvest name, number, age, bank info - tomorrow's vishing target list
- Fake ads: criminals **pay** to put fake customer-care numbers on top of search results
- Evidence trail: who ran the ad, which account paid, where the site is hosted

Evidence: Three Rules That Save Cases

Social-engineering evidence is fragile - emails get deleted, chats vanish. **Three rules:**

- **Keep the original untouched:** save the email/message as-is, note date-time of saving
- **Write every step:** what you examined, with which tool, what result - dated
- **Chain of custody:** who held the evidence, when - unbroken, or the court doubts it

Real Case: Jamtara - the Phishing Capital

Villages in Jharkhand became **industrial-scale phishing call centres**:

- Gangs posed as bank staff, extracted OTPs, drained accounts across India - hundreds of calls daily
- Complete SOP: training, scripts, panic-handling - an industry, not individuals
- Multi-state raids, hundreds arrested. Lesson: **organised crime needs organised investigation**
- Source The Indian Express

Real Case: Digital Arrest - Hostage on Video Call

2024-25: criminals as 'CBI/ED officers' hold victims **hostage for hours on video call**:

- Fake uniforms, fake offices, fake documents - even doctors and professors lost lakhs
- Victims too scared to tell anyone; the PM warned the nation about it publicly
- Investigation key: **follow the money** - fast rotation through mule accounts
- Source The Indian Express, PIB

Your Turn: Labs in This Module

Three defensive labs - you only **identify and dissect**, never create:

- **Lab 1:** Dissect a phishing email from your spam folder - full 12-point report
- **Lab 2:** Score a vishing transcript on the 6-point red-flag checklist
- **Lab 3:** Verify a suspicious QR safely - preview only, verdict: SAFE / SUSPICIOUS / MALICIOUS
- Golden rule of all labs: **never click, never download, never pay**

Mistakes That Weaken These Cases

Social-engineering cases die from **avoidable errors**:

- Clicking the phishing link 'to check' - destroys the pristine evidence state
- Letting the victim delete chats 'out of shame' - the chat IS the evidence
- Not asking where the data leaked from - the leak is a lead to the gang
- Delaying the 1930 call while 'investigating first' - money moves in minutes

What to Tell Every Victim

A panicked victim is your **best witness** - if you handle them right:

- 'Cut the call. Do not call back on their number. Call the bank's **official** number yourself.'
- 'Do not delete anything - **screenshots of every chat**, right now, with date-time visible.'
- 'Nobody genuine arrests on video call. **No officer demands money on a call.**'
- Never blame: a shamed victim stops cooperating, and cooperation is your evidence

Key Takeaways

If you remember nothing else from Module 11:

- Social engineering hacks the **human** - fear, greed and hurry are the exploit kit
- Every fraud has a **script** - identical scripts across cases mean one gang
- Dissect links and emails **without clicking**: header, SPF/DKIM/DMARC, VirusTotal
- Always ask: **where did the victim's data leak from?** - the leak is a lead
- Preserve originals, document every step, keep the **chain of custody** unbroken
- Victims are witnesses, not suspects - **protect them, don't shame them**

Review Questions

- 1. Name the three emotions exploited in social engineering, with one realistic example of each.
- 2. A victim says the caller knew her daughter's name. What does this tell you, and what is your next question?
- 3. Where in an email header do SPF/DKIM/DMARC results appear, and what does a fail mean?
- 4. Two cases in different districts use the phrase 'RBI verification, five minutes'. What do you conclude?
- 5. A QR arrived on WhatsApp promising cashback. Walk through your safe verification steps.

NEXT: MODULE 12

Social Media Crime Analysis

Fake profiles, impersonation, hijacking - evidence that stands in court